

Artificial Intelligence (AI) Working Group
Meeting Notes
July 12, 2024

Participants:

- Alec Summers
- Alex Tapley
- Bob Heinemann
- Connor Mullaly
- Christina Liaghati
- Keith Manville
- Lily Wong
- Pete Bryan
- Robert Roberge Jr.
- Steven Christey
- Timothy O'Neill

NX Support:

- Greg Kerr
- Norah Schneider
- Tori Mills

Agenda:

1. Chairs: WG Goals
2. New CWE-1426 Overview and Discussion
3. Level-set on existing content submissions

Meeting Notes:

CWE 4.15 Changes for AI/ML

- CWE 4.15 AI-related Content Summary
 - (New) CWE-1426: Improper Validation of Generative AI Output
 - (Nearly complete) Demonstrative example in CWE-77 (Command Injection)
 - Classic prompt-injection “ignore all previous instructions” on an input assumed to be of the form CWE-xxx.
 - (In Process) AI/prompt-related observed examples for SQL injection (CWE-89), path traversal (CWE-22), code injection (CWE-94), and others.
 - (To-Do) CWE-77 terminology notes on “prompt injection” explaining how it’s an attack against multiple weaknesses.
- **Re: CW-1426** – The requested examples and additional information were not all clearly aligned with the new CWE but proved useful for other examples and references.
 - With the new entry, output validation when searching for prompt injection should show multiple search prompt options.
 - Prompt-injection = command injection in its classic form.
- **Re: AI/prompt-related observed examples** – The majority of the observed examples provided were classic weaknesses that involved output from the prompt so these will remain “observed examples” for CVEs for various other weaknesses.
- **Re: CWE-77** – Within CWE-77 (command injection) We can add terminology notes that will specifically try to describe or detail prompt injection.
 - Anything related to prompts is not always prompt injection. Not all interpretations are accurate.
- **Re: AI and ML is an applicable technology class** – This item is still in process yet moving forward.

Presentation and Demo of the Draft Page

- Additional edits and revisions will be made during this group discussion.
- The draft page includes: the brief description, common consequences (with scope and impact), mitigations, relationships (seeking to be “pillared” to create different levels), modes of introduction, architectures and design, applicable platforms, observed examples, additional and maintenance notes.
 - **Re: Duplicate text for ‘Architecture and Design’ and ‘Implementation’.**
There is a limitation of current CWE in the current schema, where it is unable to give one mode of introduction that includes multiple phases. Generally,

during each phase you should have a different way to introduce the potential weakness.

- **This schema limitation will be addressed in the future.**

- **Re: Detection page** – Will be incorporated into the draft upon reviewing the conversion program. The current conversion program doesn't look at detection methods.
- Steven Christey provided a demonstrative example of CWE-77 command injection as a result of usability.

[Q] How do we credit the working group?

- Suggestion: Similar to how we credit contributions from the ICS OT CIG. To make it easier, we can use a general submitter name ("Members of the Working Group") which will include members of the working group.

Re: Research gaps in relation to CWE entry -- Diverse and dynamic terminology; is terminology evolving or is it just extending and expanding?

[Q] Do we want to continue with the current pace with less opportunity for review and feedback?

- Member recommendation: Not follow this pace but to allow time to breathe and understand and have some deeper discussions?
- Member comment: I don't know if I agree with you. I think that there's a nice balance and the community really participated. The chairs can speak more on this separately.
- Member comment: It's a larger discussion. I think it's a win despite the timeline being short. We did get tremendous engagement and we can work on the balance. We can continue to talk more on this moving forward.

Wrap Up/Action Items:

- **CWE 5.0** – Fall release expected in October. New entry on a classic style prompt injection.
- **CWE 1426** – Need to make improvements over the next couple of months and need to develop a good demonstrative example.
 - Will figure out with the Chairs to decide on how to prioritize and move forward.
- Address the other prompt injection submissions that aren't directly related to prompt injection. These are likely to generate fruitful discussions and potential new entries as well.

- Member comment: consider marching towards a few KPIs. “Sometimes people might have some resistance around measurements, but I think if you have a few concrete things that we're going to march toward between now and December, it does give us something that is clear and keeps the group on the same page so that we know where the areas are that we need to grow with.”